🕷️

🧪 18 — Automated Scanning Results (ZAP + Nikto)

Automated Vulnerability Scanning

Purpose: Complement manual testing with automated tools for comprehensive coverage.

🤖 Tool 1: OWASP ZAP

Setup & Scan

```
# Start ZAP
zap.sh
# OR docker:
docker run -t owasp/zap2docker-stable zap-baseline.py -t http://localho
st/bWAPP/

# Authenticated scan (use session cookie):
zap-cli --zap-url http://localhost -p 8080 quick-scan \
  --spider http://localhost/bWAPP/ \
  --scanners all \
  --start-options "-config api.disablekey=true"
```

Findings from ZAP Scan on bWAPP

Vulnerability	Risk	Endpoint
SQL Injection	High	/sqli_1.php
XSS Reflected	High	/xss_get.php
CSRF	Medium	/csrf_1.php
Open Redirect	Medium	/unvalidated_redirects_1.php
Clickjacking	Medium	(no X-Frame-Options)
Insecure Headers	Low	Multiple
Information Disclosure	Low	/phpinfo.php

🔍 Tool 2: Nikto

```
# Basic scan
nikto -h http://localhost/bWAPP/
```

```
# Save output
nikto -h http://localhost/bWAPP/ -output nikto_results.txt

# With authentication
nikto -h http://localhost/bWAPP/ -id bee:bug

# With cookie
nikto -h http://localhost -c 'PHPSESSID=xxxx; security_level=0'
```

Typical Nikto Findings on bWAPP

```
+ /bWAPP/phpinfo.php: PHP info file found
+ /bWAPP/admin/: Admin directory accessible
+ /bWAPP/.htaccess: htaccess file found
+ Apache version disclosure in Server header
+ TRACE method enabled (HTTP verb tampering risk)
+ X-Frame-Options header not set
+ X-Content-Type-Options header not set
+ Outdated Apache version detected
```

🔍 Tool 3: SQLMap Automated Scan

```
# Crawl and test all SQL injectable params
sqlmap -u "http://localhost/bWAPP/sqli_1.php?title=test&action=search"
\
  --cookie="PHPSESSID=xxxx;security_level=0" \
  --batch \
  --level=3 \
  --risk=2 \
  --dbs \
  --output-dir=./sqlmap_results/
```

🔍 Tool 4: Burp Suite Scanner

```
1. Configure browser proxy -> 127.0.0.1:8080
2. Add http://localhost to scope
3. Browse all bWAPP pages while logged in (Burp captures traffic)
4. Right-click site in Site Map -> Scan
5. Active Scan -> Run
6. Review findings in Dashboard
```

📊 Complete Vulnerability Summary Table

#	Vulnerability	Severity	CVSS	CWE	Status
1	HTML Injection Reflected	High	7.5	CWE-79	Confirmed
2	HTML Injection Stored	High	8.0	CWE-79	Confirmed
3	iFrame Injection	Medium	6.1	CWE-79	Confirmed
4	OS Command Injection	Critical	9.8	CWE-78	Confirmed
5	PHP Code Injection	Critical	9.8	CWE-94	Confirmed
6	SSI Injection	High	8.8	CWE-97	Confirmed
7	SQL Injection GET	Critical	9.8	CWE-89	Confirmed
8	SQL Injection POST	Critical	9.8	CWE-89	Confirmed
9	SQL Injection Login	Critical	9.8	CWE-89	Confirmed
10	Blind SQL Injection Boolean	High	8.8	CWE-89	Confirmed
11	Blind SQL Injection Time	High	8.8	CWE-89	Confirmed
12	XSS Reflected GET	High	7.5	CWE-79	Confirmed
13	XSS Reflected POST	High	7.5	CWE-79	Confirmed
14	XSS Stored Blog	High	8.8	CWE-79	Confirmed
15	XSS DOM-Based	High	7.5	CWE-79	Confirmed
16	CSRF	High	8.8	CWE-352	Confirmed
17	LFI	Critical	9.1	CWE-73	Confirmed
18	RFI	Critical	9.8	CWE-73	Confirmed
19	File Upload	Critical	9.8	CWE-434	Confirmed
20	XXE	Critical	9.1	CWE-611	Confirmed
21	SSRF	Critical	9.8	CWE-918	Confirmed
22	Clickjacking	Medium	5.4	CWE-1021	Confirmed
23	Open Redirect	Medium	6.1	CWE-601	Confirmed
24	Broken Auth	Critical	9.8	CWE-287	Confirmed
25	Session Fixation	High	8.0	CWE-384	Confirmed

#	Vulnerability	Severity	CVSS	CWE	Status
26	IDOR	High	7.5	CWE-639	Confirmed
27	Missing Access Control	High	8.8	CWE-284	Confirmed
28	Sensitive Data Exposure	High	7.5	CWE-312	Confirmed
29	HTTP Response Splitting	Medium	5.4	CWE-113	Confirmed
30	XPath Injection	High	7.5	CWE-643	Confirmed
31	LDAP Injection	High	7.5	CWE-90	Confirmed
32	Buffer Overflow	Critical	9.8	CWE-121	Simulated
33	PHP Code Injection eval	Critical	9.8	CWE-94	Confirmed

📄 Executive Summary

A comprehensive vulnerability assessment of bWAPP across **Low, Medium, and High** security levels identified **33 distinct vulnerabilities**. All OWASP Top 10 categories were represented. Critical findings include multiple injection vulnerabilities (SQL, OS Command, PHP Code, XXE) and broken access controls. All vulnerabilities were validated with manual PoC exploits and documented with remediation recommendations.

Risk Distribution:

- Critical: 12 findings (CVSS 9.0+)
- High: 16 findings (CVSS 7.0-8.9)
- Medium: 5 findings (CVSS 4.0-6.9)

> 📝 **This report was authored by Vedant Sareen as part of a self-directed vulnerability assessment project (Jan-July 2024). All testing was conducted in a legal, isolated lab environment.**

GitHub: https://github.com/VedantSareen/REPORTS_DVWA-BWAPP_POC

LinkedIn: https://linkedin.com/in/sareen-cybersecurity-477180ved